

Contents

Volume 05 — Lectures 41–50: Passwords, Malware & Hardware Security	1
L41: Password Cracking	1
L42: Phishing Attack	2
L43: Malware	3
L44: Wi-Fi Hacking	4
L45: DoS and DDoS Attack	5
L46: Elements of Hardware Security	6
L47: Side Channel Attacks — Part I	6
L48: Side Channel Attacks — Part II	7
L49: Physical Unclonable Function	8
L50: Hardware Trojan	9

Volume 05 — Lectures 41–50: Passwords, Malware & Hardware Security

Ethical Hacking · NPTEL 106105217 · Prof. Indranil Sengupta

L41: Password Cracking

Concepts

- **Password storage:** never plaintext; hash with salt + slow algorithm (bcrypt, Argon2).
- **Windows hashes:** LM (obsolete, case-insensitive, 7-char chunks) and NTLM (MD4 of UTF-16LE password).
- **Linux hashes:** MD5 (\$1\$), SHA-256 (\$5\$), SHA-512 (\$6\$), bcrypt (\$2a\$), yescrypt.
- **Attack types:** dictionary, brute-force, hybrid, rule-based, rainbow tables.
- **Pass-the-hash:** authenticate using NTLM hash without cracking plaintext.

Tools

- **John the Ripper:** `john --wordlist=rockyou.txt hashes.txt`
- **Hashcat:** `hashcat -m 1000 -a 0 hashes.txt rockyou.txt` (NTLM = mode 1000)
- **Hydra:** `hydra -l admin -P passwords.txt ssh://target`
- **Mimikatz:** `sekurlsa::logonpasswords` (extract hashes from memory)
- **Medusa, Ncrack** — network login brute-force

Attack Steps

1. Obtain hashes: `hashdump` (Meterpreter), `/etc/shadow`, `NTDS.dit` (AD).
2. Identify hash type: `hashid` or `hash-identifier`.
3. Dictionary attack: `hashcat -m 1000 -a 0 hashes.txt rockyou.txt`.
4. Rule-based mutation: `hashcat -m 1000 -a 0 hashes.txt rockyou.txt -r best64.rule`.
5. Pass-the-hash: `pth-winexe //target cmd` or `crackmapexec smb target -u user -H hash`.

Defenses

- Password policy: length 12, complexity, no common passwords
- MFA on all accounts
- Account lockout / rate limiting
- Use Argon2id/bcrypt for application password storage
- Credential Guard (Windows) to protect LSASS

Exam Bullets

- NTLM hash = **MD4** of password; Hashcat mode **1000**.
 - Dictionary attack tries **wordlist entries**; brute-force tries all combinations.
 - Rainbow tables are precomputed — defeated by **salting**.
 - Pass-the-hash uses **NTLM hash directly** without cracking plaintext.
 - LM hash splits password into **7-character chunks** (case-insensitive).
-

L42: Phishing Attack

Concepts

- **Phishing types:** mass phishing, spear phishing (targeted), whaling (executives), vishing (voice), smishing (SMS).
- **Attack chain:** recon → craft lure → deliver payload → capture credentials → establish access.
- **Indicators:** mismatched URLs, urgency language, generic greetings, suspicious attachments.
- **Clone phishing:** copy legitimate email, replace links/attachments with malicious versions.
- **Business Email Compromise (BEC):** impersonate executive to authorize wire transfers.

Tools

- **SET (Social Engineering Toolkit):** credential harvester
- **GoPhish:** open-source phishing framework
- **Evilginx2:** adversary-in-the-middle phishing (bypasses MFA)
- **King Phisher:** campaign management
- Email spoofing: **swaks**, SMTP open relays

Attack Steps

1. Recon target organization (email format, executives, current events).
2. Register lookalike domain (e.g., **micr0soft.com**).
3. Craft email with urgency (“Password expires today”).
4. Host cloned login page; capture credentials on submission.
5. Use stolen credentials immediately (before password reset).

Defenses

- Security awareness training with simulated phishing
- SPF + DKIM + DMARC (p=reject)
- Email gateway filtering and link sandboxing

- MFA (hardware tokens resist Evilginx2 better than SMS)
- Report-phishing button for employees

Exam Bullets

- Spear phishing targets **specific individuals** with personalized content.
 - Clone phishing **replicates legitimate emails** with malicious modifications.
 - Evilginx2 performs **AiTM (adversary-in-the-middle)** to steal session cookies.
 - DMARC p=reject blocks emails failing **SPF and DKIM** checks.
 - Whaling targets **C-level executives** (high-value targets).
-

L43: Malware

Concepts

- **Malware categories:** virus (needs host), worm (self-replicating), trojan (disguised), ransomware, spyware, rootkit, adware.
- **Propagation:** email attachments, drive-by download, USB, exploit kits, lateral movement.
- **Persistence mechanisms:** registry Run keys, scheduled tasks, services, DLL hijacking, firmware.
- **Anti-analysis:** packing, obfuscation, VM/sandbox detection, encrypted strings.
- **RAT (Remote Access Trojan):** provides attacker remote control (DarkComet, njRAT, Cobalt Strike).

Tools

- **Analysis (static):** strings, pefile, Ghidra, IDA Pro
- **Analysis (dynamic):** Cuckoo Sandbox, ANY.RUN, Wireshark
- **Detection:** clamav, Windows Defender, rkhunter, chkrootkit
- **YARA rules:** pattern matching for malware families

Attack Steps

1. Deliver payload via phishing attachment or exploit kit.
2. Execute: macro-enabled document, PowerShell download cradle, DLL side-loading.
3. Establish persistence (registry, scheduled task).
4. C2 communication: HTTP/HTTPS beacon to command server.
5. Lateral movement and data exfiltration.

Defenses

- Endpoint Detection and Response (EDR)
- Application whitelisting
- Disable macros by default in Office
- Network monitoring for C2 beacon patterns
- Regular backups (ransomware recovery)

Exam Bullets

- Virus requires **host program**; worm spreads **autonomously**.
 - Trojan **disguises** as legitimate software (user-initiated execution).
 - Rootkit operates at **kernel/firmware level** — hides from OS.
 - Packing/obfuscation defeats **signature-based** AV detection.
 - RAT provides **remote access and control** over infected system.
-

L44: Wi-Fi Hacking

Concepts

- **802.11 standards:** a (5 GHz), b/g (2.4 GHz), n (MIMO), ac/ax (Wi-Fi 5/6).
- **Authentication:** Open, WEP (broken), WPA (TKIP, deprecated), WPA2 (AES-CCMP), WPA3 (SAE).
- **4-way handshake:** AP client key exchange; captures used for offline cracking.
- **Monitor mode:** NIC captures all wireless frames (not just associated BSS).
- **Deauthentication attack:** forged deauth frames disconnect clients (capture handshake on reconnect).

Tools

- **Aircrack-ng suite:**
 - `airmon-ng start wlan0` — enable monitor mode
 - `airodump-ng wlan0mon` — capture packets
 - `aireplay-ng --deauth 10 -a AP_MAC wlan0mon` — deauth attack
 - `aircrack-ng -w rockyou.txt capture.cap` — crack WPA handshake
- **Wifite2:** automated Wi-Fi auditing
- **hashcat -m 22000:** crack WPA-PBKDF2-PMKID

Attack Steps

1. Enable monitor mode: `airmon-ng start wlan0`.
2. Scan networks: `airodump-ng wlan0mon` — note BSSID and channel.
3. Capture handshake: `airodump-ng -c CH --bssid BSSID -w capture wlan0mon`.
4. Deauth client: `aireplay-ng --deauth 5 -a BSSID -c CLIENT wlan0mon`.
5. Crack: `aircrack-ng -w rockyou.txt capture-01.cap`.

Defenses

- WPA3 with SAE (resistant to offline dictionary attacks)
- Strong passphrase (15 random characters)
- 802.11w (protected management frames) prevents deauth attacks
- Enterprise WPA2-Enterprise (802.1X/RADIUS) — per-user credentials
- Wireless IDS monitoring for rogue APs

Exam Bullets

- WEP uses **RC4** — cracked in minutes; never use.

- WPA2-PSK crack requires capturing **4-way handshake** or PMKID.
 - Deauth attack sends forged **deauthentication frames** to disconnect clients.
 - Monitor mode captures **all wireless traffic** on channel (promiscuous for Wi-Fi).
 - WPA3 SAE replaces PSK with **dragonfly key exchange** (anti offline-dict).
-

L45: DoS and DDoS Attack

Concepts

- **DoS**: single source overwhelms target; **DDoS**: distributed attack from botnet (zombies).
- **Attack types**:
 - Volume-based: UDP flood, ICMP flood, DNS amplification
 - Protocol-based: SYN flood, Ping of Death
 - Application-layer: HTTP flood, Slowloris, RUDY
- **Amplification**: small query → large response (DNS, NTP, memcached reflection).
- **Botnet**: network of compromised machines (Mirai, Emotet) controlled by C2 server.

Tools

- `hping3 --flood --syn -p 80 target` — SYN flood
- `slowloris.py target` — slow HTTP headers
- LOIC / HOIC (lab only) — stress testing
- `nping` — custom packet crafting

Attack Steps

1. **SYN flood**: send SYN packets without completing handshake → exhaust connection table.
2. **DNS amplification**: spoof source IP as victim; query open resolvers → flood victim with responses.
3. **HTTP flood**: botnet sends legitimate-looking HTTP requests to exhaust server resources.
4. **Slowloris**: open many connections; send partial HTTP headers slowly to hold connections open.

Defenses

- SYN cookies (kernel-level SYN flood mitigation)
- Rate limiting and traffic shaping
- CDN/DDoS scrubbing services (Cloudflare, Akamai)
- Anycast distribution to absorb volume
- Close unnecessary services (NTP, memcached) on public interfaces

Exam Bullets

- SYN flood exploits **TCP 3-way handshake** — fills connection queue with half-open connections.
- DNS amplification achieves **bandwidth multiplication** (small query, large response).
- Slowloris is **application-layer** attack — holds connections with incomplete requests.
- Botnet = **network of compromised machines** controlled by attacker (C2).

- DDoS mitigation: **rate limiting** + **CDN scrubbing** + **SYN cookies**.
-

L46: Elements of Hardware Security

Concepts

- **Hardware root of trust:** secure boot chain from immutable ROM (TPM, secure enclave).
- **TPM (Trusted Platform Module):** hardware chip storing keys, measurements, attestation.
- **Secure boot:** verify firmware/OS signatures before execution (UEFI Secure Boot).
- **Hardware Security Module (HSM):** dedicated crypto processor for key management.
- **TrustZone (ARM) / SGX (Intel):** isolated execution environments (TEE).

Tools

- `tpm2_tools` — interact with TPM 2.0
- `me_cleaner` — Intel ME analysis
- JTAG/UART debug interfaces (hardware debugging)
- Oscilloscope / logic analyzer (side-channel analysis)

Attack Steps

1. Bypass secure boot via bootkit (evil maid attack on unverified media).
2. Extract keys from TPM if physical access and no PIN protection.
3. JTAG debugging to dump firmware from embedded device.
4. Fault injection to glitch secure boot verification (voltage/clock glitch).

Defenses

- Enable UEFI Secure Boot with vendor + custom keys
- TPM-based disk encryption (BitLocker, LUKS with TPM binding)
- Disable JTAG/debug interfaces in production
- Physical tamper detection (enclosure switches, epoxy)

Exam Bullets

- TPM provides **hardware root of trust** for key storage and attestation.
 - Secure Boot verifies **digital signatures** of firmware/OS before loading.
 - HSM = dedicated hardware for **crypto key management** (high-security environments).
 - TrustZone/SGX create **Trusted Execution Environments** isolated from main OS.
 - Evil maid attack: physical access to **tamper with boot process**.
-

L47: Side Channel Attacks — Part I

Concepts

- **Side-channel attack:** exploit physical implementation leakage, not algorithm weakness.
- **Power analysis:** measure power consumption during crypto operations.

- **SPA (Simple Power Analysis)**: visual inspection of power traces.
- **DPA (Differential Power Analysis)**: statistical correlation of traces with key bits.
- **Timing attack**: measure operation duration to infer secret data (Kocher 1996).
- **Electromagnetic (EM) leakage**: capture EM emissions from chip during computation.

Tools

- ChipWhisperer — hardware platform for power analysis
- Oscilloscope + differential probe
- oscilloscope + Python analysis scripts
- OpenADC for signal capture

Attack Steps

1. Connect probe to power rail of target crypto chip.
2. Trigger encryption with known plaintext; capture power trace.
3. DPA: correlate power consumption with hypothesized key bits.
4. Repeat for sufficient traces to recover full AES key (typically 1000–5000 traces).

Defenses

- **Masking**: randomize intermediate values in crypto operations
- **Constant-time implementations**: prevent timing variations
- **Power/EM shielding**: Faraday cage, filtering capacitors
- **Noise injection**: add random operations to obscure signal

Exam Bullets

- Side-channel attacks exploit **physical leakage** (power, timing, EM), not math weaknesses.
 - DPA uses **statistical analysis** of many power traces to recover key bits.
 - SPA requires **visual inspection** of single/few power traces.
 - Timing attack: measure **operation duration** to infer secret (e.g., RSA key bits).
 - Constant-time code prevents **timing side channels**.
-

L48: Side Channel Attacks — Part II

Concepts

- **Cache timing attacks**: exploit CPU cache behavior (Flush+Reload, Prime+Probe).
- **Spectre/Meltdown**: CPU speculative execution leaks data across security boundaries.
- **Acoustic cryptanalysis**: recover RSA keys from coil whine (disk encryption).
- **Fault injection**: glitch voltage/clock/laser to cause computation errors → leak key material.
- **Rowhammer**: repeatedly access DRAM rows to flip bits in adjacent rows.

Tools

- cachegrab — cache timing attack framework
- Rowhammer test tools (**rowhammer-test**)
- Voltage glitching with ChipWhisperer

- meltdown / spectre PoC code (lab VMs only)

Attack Steps

1. **Flush+Reload:** flush shared cache line; measure reload time to detect victim access.
2. **Fault injection:** glitch voltage during RSA signature to produce faulty output → factor modulus.
3. **Rowhammer:** hammer aggressor rows to flip bit in victim page (bypass browser sandbox).
4. **Spectre:** train branch predictor to leak data across process boundaries.

Defenses

- Microcode updates for Spectre/Meltdown mitigations
- Cache partitioning (CAT — Cache Allocation Technology)
- ECC memory against Rowhammer
- Double-and-add randomization in crypto implementations

Exam Bullets

- Meltdown breaks **user/kernel isolation** via speculative execution.
 - Spectre tricks programs into **leaking data** via mispredicted branches.
 - Rowhammer exploits **DRAM physical proximity** to flip bits without direct access.
 - Fault injection (voltage/clock glitch) causes **computation errors** revealing key material.
 - Flush+Reload is a **cache timing attack** on shared cache lines.
-

L49: Physical Unclonable Function

Concepts

- **PUF (Physical Unclonable Function):** hardware instance-specific challenge-response based on manufacturing variations.
- **Types:** SRAM PUF (power-on state), ring oscillator PUF, arbiter PUF, optical PUF.
- **Properties:** uniqueness (different chips → different responses), reliability (same challenge → same response), unclonability.
- **Applications:** device authentication, key generation, anti-counterfeiting, secure boot binding.
- **FPGA/IC fingerprinting:** identify specific hardware instance without stored secret.

Tools

- PUF simulation frameworks (academic)
- Xilinx FPGA PUF implementations
- Statistical analysis for uniqueness/reliability testing

Attack Steps

1. **Modeling attack:** collect challenge-response pairs → build ML model predicting responses.
2. **Reliability attack:** exploit environmental sensitivity (temperature, voltage) to cause errors.
3. **Tamper to clone:** physically probe and replicate delay characteristics (extremely difficult).

Defenses

- Helper data schemes (fuzzy extractors) for error correction without revealing PUF
- Limit exposed challenge-response pairs (prevent modeling)
- Combine PUF with secure enclave
- Environmental monitoring to detect tampering

Exam Bullets

- PUF exploits **manufacturing variations** for unique device identity.
 - PUF response is **unclonable** — cannot replicate on different chip.
 - SRAM PUF uses **power-on random state** of uninitialized SRAM.
 - Modeling attack uses **ML on C-R pairs** to clone PUF behavior.
 - PUF used for **device authentication** and **key derivation**.
-

L50: Hardware Trojan

Concepts

- **Hardware Trojan:** malicious modification to IC/hardware at design, fabrication, or assembly stage.
- **Trojan types:** functional (change behavior) vs parametric (degrade performance); trigger: always-on, condition-based.
- **Insertion points:** RTL design, synthesis, placement, fabrication (untrusted foundry).
- **Payloads:** information leakage, denial of service, privilege escalation, kill switch.
- **Detection difficulty:** no equivalent of AV for hardware; golden chip comparison required.

Tools

- Formal verification tools (model checking)
- Side-channel analysis for anomalous power signatures
- X-ray/tomography for die inspection
- Logic testing with ATPG (Automatic Test Pattern Generation)

Attack Steps

1. **Design-level:** insert trigger circuit in RTL (e.g., activate on specific input pattern).
2. **Fab-level:** untrusted foundry adds extra circuitry during manufacturing.
3. **Supply chain:** substitute genuine chip with trojaned clone.
4. Payload: leak AES key via power pin when trigger condition met.

Defenses

- Trusted foundry and supply chain verification
- Split manufacturing (no single entity has full design)
- Runtime monitoring for anomalous behavior
- Formal verification of RTL against golden reference
- Physical inspection (destructive testing of sample chips)

Exam Bullets

- Hardware Trojan inserted at **design, fabrication, or assembly** stage.
- Functional Trojan **changes circuit behavior**; parametric degrades performance.
- Trigger types: **always-on** or **condition-based** (rare input pattern).
- Untrusted foundry is primary threat in **offshore chip manufacturing**.
- Detection requires **golden chip comparison** or side-channel anomaly analysis.

Previous: [Volume 04](#) · *Next:* [Volume 06 — Web Vulnerabilities & Advanced Tools](#)